

AI Act — co musisz wiedzieć, żeby bezpiecznie korzystać z AI w firmie

Praktyczny przewodnik dla pracowników i menedżerów — bez prawniczego żargonu, z konkretnymi przykładami i liczbami, które mają znaczenie dla Twojej codziennej pracy.

ROZPORZĄDZENIE (UE) 2024/1689

ZAKTUALIZOWANE: DIGITAL OMNIBUS 2026



Dlaczego to nas dotyczy

Prawo unijne, które dotyczy każdej firmy w UE

Hierarchia prawa

Na szczycie stoi prawo unijne — **AI Act (Rozporządzenie (UE) 2024/1689)** — a dopiero pod nim prawo krajowe: RODO, prawo autorskie, Kodeks pracy. Te ostatnie jedynie doprecyzowują AI Act, nie zastępują go.

Mapa regulacyjna



Dlaczego AI Act dotyczy każdej firmy w UE

Hierarchia prawa jest prosta

AI Act stoi na szczycie – powyżej RODO, prawa autorskiego i Kodeksu pracy. Obowiązuje **bezpośrednio** w każdym kraju UE, bez potrzeby osobnej ustawy krajowej – tak samo jak RODO.

Kogo obejmuje?

Każdej firmy sprzedającej produkty lub usługi konsumentom w UE – niezależnie od kraju rejestracji. Firma z USA, Chin czy Polski jest traktowana tak samo.

Harmonogram wdrożenia AI Act 2024–2028



Digital Omnibus — co realnie się zmieniło?

Regulation (EU) 2026/1744, w mocy od 27 lipca 2026, zmienia kalendarz wdrożenia AI Act dla systemów wysokiego ryzyka.

Co zostało przesunięte

Pełne stosowanie przepisów o systemach wysokiego ryzyka: **Załącznik III → 2 grudnia 2027**, Załącznik I → 2 sierpnia 2028. Dłuższy czas na dostosowanie dla firm.

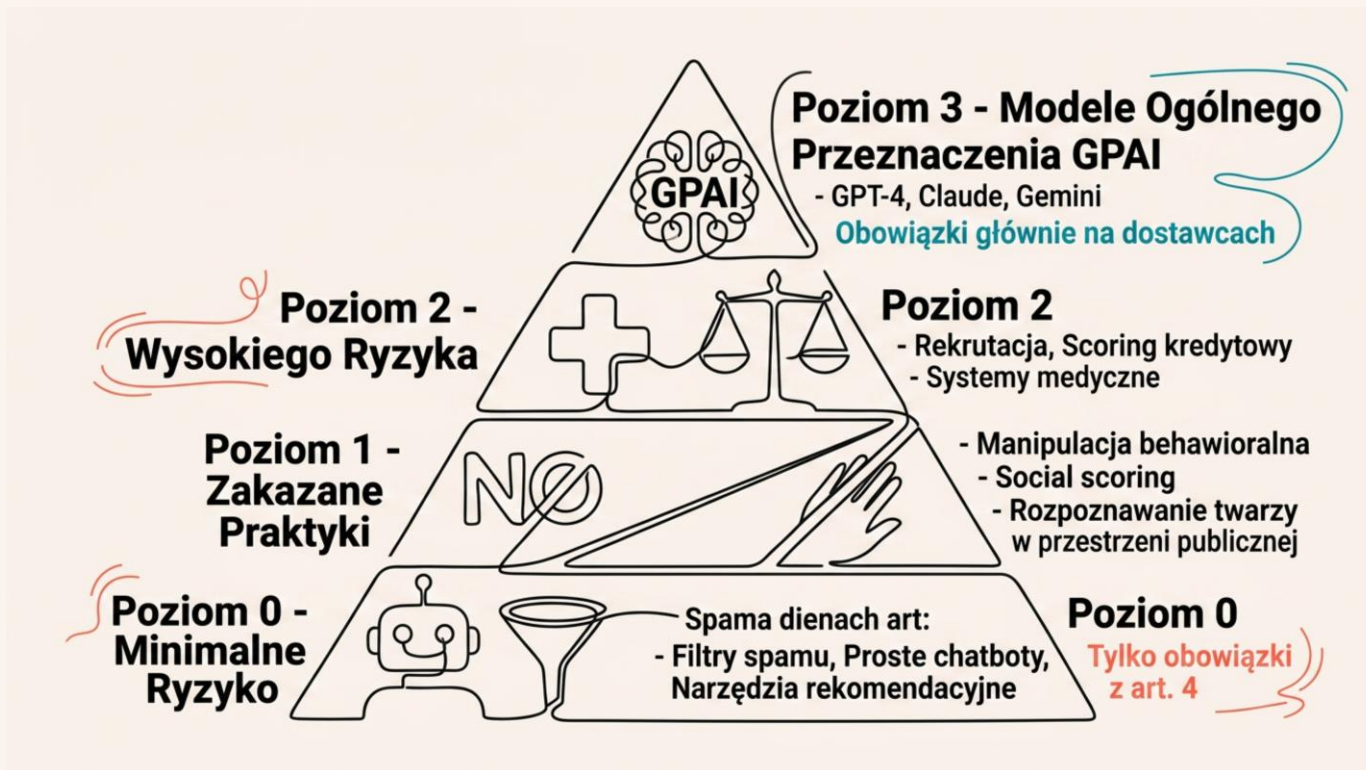
Co NIE zostało przesunięte

Art. 50 (transparentność) obowiązuje od **2 sierpnia 2026**. Jedynie techniczny obowiązek znakowania treści (art. 50 ust. 2) ma krótki okres przejściowy do 2 grudnia 2026.

Nowe zakazy od 2.12.2026

Treści intymne bez zgody ("nudifier apps") i materiały CSAM. Dodatkowe złagodzenia dla MŚP i centralizacja nadzoru nad GPAI w Urzędzie ds. AI UE.

Cztery poziomy ryzyka — mapa AI Act



Poziomy 2 i 3 to te, które **realnie dotyczą** firm korzystających z AI na co dzień. Klasyfikacja zależy nie tylko od modelu, ale przede wszystkim od **celu i kontekstu zastosowania**.



Poziom 1 — praktyki całkowicie zakazane (art. 5)

Manipulacja behawioralna

Systemy AI wpływające na zachowanie ludzi w sposób, którego nie są świadomi — np. celowe wykorzystywanie słabości psychologicznych do nakłaniania do decyzji.

Social scoring obywateli

Ocenianie lub rankingowanie osób przez władze publiczne na podstawie ich zachowania społecznego lub cech osobistych — zakazane całkowicie.

Masowe rozpoznawanie twarzy

Identyfikacja biometryczna w przestrzeni publicznej w czasie rzeczywistym — zakazana, z wąskimi wyjątkami dla służb bezpieczeństwa.

Od 2 grudnia 2026 — nowe zakazy

"Nudifier apps" (treści intymne bez zgody) i generowanie materiałów CSAM. Kary za naruszenia poziomu 1 są najwyższe — do 35 mln € lub 7% obrotu globalnego.

Poziom 2 — systemy wysokiego ryzyka

Czym są?

Systemy AI, które mogą wpływać na **życie, zdrowie, bezpieczeństwo, prawa i wolności** ludzi. Ich stosowanie jest dozwolone — ale wymaga spełnienia rozbudowanego katalogu obowiązków z art. 26.

Kluczowe obszary (Załącznik III)

- Zatrudnienie i zarządzanie pracownikami (rekrutacja, ocena)
- Dostęp do usług finansowych (scoring kredytowy)
- Edukacja i szkolenia zawodowe
- Systemy opieki zdrowotnej i medyczne
- Zarządzanie infrastrukturą krytyczną

Najczęstszy błąd firm

Firmy wpadają w poziom 2 **nieświadomie** — nie dlatego, że wybrały "zaawansowany" model AI, ale dlatego, że użyły zwykłego narzędzia (np. ChatGPT) w ryzykownym kontekście (np. ocena kandydatów do pracy).

Pytanie kluczowe brzmi nie **"jaki model?"**, ale **"do czego go używam?"**

Poziom 3 — modele ogólnego przeznaczenia (GPA)

Szczególna kategoria dla dużych modeli językowych takich jak GPT-4, Claude, Gemini. Obowiązki spoczywają głównie na dostawcach, ale firma korzystająca z API ma własne, węższe obowiązki.



Dostawca (OpenAI, Google...)

Odpowiada za dokumentację techniczną modelu, politykę praw autorskich, zgłoszenie do rejestru Urzędu ds. AI UE, przestrzeganie kodeksów praktyk.



Deployer (Twoja firma)

Odpowiada za cel i kontekst zastosowania, szkolenia pracowników (AI literacy), nadzór ludzki i zgodność z regulaminem dostawcy. Nie jest "czysta" tylko dlatego, że model pochodzi z zewnątrz.



Granica między 2 i 3

Codziennie korzystanie z czatu AI zaczyna się na poziomie 3 — ale może łatwo przejść do poziomu 2, jeśli zastosowanie wchodzi w obszary Załącznika III. To pułapka, o której mówi następna karta.



Pułapka: kiedy zwykły czat AI staje się systemem wysokiego ryzyka



Art. 6 ust. 1 w zw. z Załącznikiem III: system AI jest wysokiego ryzyka, gdy jest stosowany w określonych obszarach — niezależnie od tego, jaki model leży u jego podstaw.

Codzienne użycie ChatGPT czy Claude może zostać zaklasyfikowane jako system wysokiego ryzyka — **nie przez sam model, tylko przez kontekst i cel zastosowania**. To jeden z najczęściej pomijanych aspektów przy wdrażaniu AI w firmie.

1

Używasz ChatGPT

Model GPT, poziom 3 — sam w sobie nie jest wysokiego ryzyka

2

Do oceny kandydatów

Zastosowanie w obszarze "zatrudnienie" z Załącznika III pkt 4

3

Jesteś deployerem

Systemu wysokiego ryzyka z pełnymi obowiązkami art. 26 — bez ostrzeżenia

Przykład 1: Rekrutacja i ranking kandydatów

Scenariusz

HR manager używa ChatGPT do stworzenia rankingu kandydatów do pracy na podstawie przesłanych CV. Operacja trwa kilka minut – model wydaje się "zwykłym narzędziem".

Co mówi prawo

Mimo że ChatGPT to model GPT (poziom 3), jego użycie do rekrutacji wpada w kategorię **"systemy AI w zatrudnieniu i zarządzaniu pracownikami"** z Załącznika III pkt 4. Firma automatycznie staje się deployerem systemu wysokiego ryzyka.

Konsekwencje

Pełne obowiązki z art. 26:

- Nadzór ludzki nad decyzjami
- Logi z każdej sesji (min. 6 mies.)
- Informacja dla kandydatów
- Ocena ryzyka dyskryminacji
- Zgłoszenie incydentów do organu



Przykład 2: Scoring kredytowy

Firma finansowa używa modelu AI – nieważne jakiego producenta – do oceny zdolności kredytowej klientów. Samo zastosowanie kwalifikuje system jako **wysokiego ryzyka (Załącznik III pkt 5 lit. b)**, bez względu na to, czy model pochodzi od OpenAI, Google, własnego zespołu data science czy zewnętrznego software house'u.

Wniosek z obu przykładów

Pytaj nie "jaki model?", tylko "do czego go używam?" – to kontekst zastosowania decyduje o klasyfikacji, nie nazwa produktu ani dostawcy.

Zasada praktyczna

Każde nowe zastosowanie AI w firmie powinno przejść przez **test trzech warunków** (następna karta) zanim zostanie wdrożone – nawet jeśli narzędzie "wygląda" niewinnie.

Test trzech warunków — kiedy AI NIE jest wysokiego ryzyka

System AI nie jest wysokiego ryzyka tylko wtedy, gdy **łącznie** spełnia wszystkie trzy warunki (art. 6 ust. 3). Brak choćby jednego oznacza klasyfikację jako wysokiego ryzyka.

1 Wyłącznie wąskie zadanie techniczne

System wykonuje tylko ściśle określoną funkcję techniczną — np. automatyczne formatowanie dokumentu, sprawdzanie pisowni, konwersja formatów plików. Nie analizuje, nie ocenia, nie klasyfikuje ludzi.

2 Służy jedynie do poprawiania błędów

System pomaga skorygować już wykonaną pracę człowieka — nie tworzy nowych wniosków, nie generuje rankingów, nie proponuje decyzji dotyczących innych osób.

3 Nie wpływa na ostateczną decyzję

System AI nie jest jednym z czynników, na podstawie których podejmowana jest decyzja dotycząca konkretnej osoby — jej zatrudnienia, kredytu, leczenia, uprawnień.

Obowiązki deployera systemu wysokiego ryzyka (art. 26)



Zgodność z instrukcjami

Korzystanie wyłącznie zgodnie z instrukcją obsługi dostawcy – wykroczenie poza przeznaczenie systemu to Twoja odpowiedzialność, nie dostawcy.



Nadzór ludzki

Wyznaczenie wykwalifikowanych, **przeszkolonych** osób odpowiedzialnych za monitorowanie systemu i możliwość interwencji w każdej chwili.



Jakość danych wejściowych

Dane podawane do systemu muszą być **istotne i reprezentatywne** dla celu zastosowania – złe dane wejściowe to ryzyko dyskryminacji i naruszenia.



Zgłaszanie incydentów

Przy poważnym incydencie: **przerwać korzystanie** → **poinformować dostawcę** → **poinformować organ nadzorczy**. Kolejność ma znaczenie prawne.

Logi i dokumentacja — obowiązek "czarnej skrzynki" (art. 26 ust. 5)

Co musi rejestrować system?

- Jakie dane wejściowe dostał
- Jaki wynik lub decyzję wygenerował
- Kiedy to się stało (znacznik czasu)
- Kto z systemu korzystał

Te logi muszą być **automatycznie** generowane przez sam system — nie wystarczy ręczna notatka pracownika.

Jak długo przechowywać?

Minimum **6 miesięcy** — chyba że inne przepisy każą dłużej: RODO, regulacje bankowe, medyczne.

Przykład praktyczny

Używasz AI do oceny CV? Musisz być w stanie wyciągnąć log "kto/co/kiedy" sprzed pół roku — nie tylko bieżący wynik. Sprawdź z dostawcą **przed** wdrożeniem, czy system w ogóle generuje eksportowalne logi.



AI Literacy – obowiązek szkoleń (art. 4)



Obowiązuje od 2 sierpnia 2025 – dotyczy każdej firmy korzystającej z AI, nie tylko systemów wysokiego ryzyka.

Rozumienie systemu

Pracownicy muszą wiedzieć, jak działa stosowany system AI – jakie dane przetwarza, jak podejmuje decyzje, jakie są jego możliwości.

Znajomość ograniczeń

Pracownicy muszą znać typowe błędy i słabe strony systemu – np. skłonność do halucynacji, stronniczość wynikającą z danych treningowych.

Ocena krytyczna

Pracownicy muszą potrafić krytycznie ocenić output AI – nie przyjmować go bezkrytycznie jako "prawdy". To właśnie ten obowiązek uzasadnia to szkolenie.

Shadow AI — ryzyko, o którym nikt nie mówi

Co to jest Shadow AI?

Korzystanie z narzędzi AI w pracy **bez wiedzy, zgody i nadzoru firmy** — np. pracownik wkleja dane klienta do prywatnego, darmowego konta ChatGPT, bo tak jest szybciej i wygodniej.

Dlaczego to groźne?

- Firma nie wie, jakie dane wypływają na zewnątrz
- Dane mogą trafiać do trenowania modelu
- Firma nie może spełnić AI literacy (art. 4)
- Brak możliwości nadzoru systemu wys. ryzyka

Jak przeciwdziałać?

Zakaz "na papierze" nie działa — pracownicy i tak będą korzystać z tego, co znają. Skuteczne rozwiązanie to:

- **Jasna polityka AI** — co wolno, jakich narzędzi używać
- **Zatwierdzona alternatywa firmowa** — żeby pracownicy nie musieli szukać własnych rozwiązań
- **Szkolenia** — nie tylko zakazy, ale wyjaśnienie dlaczego
- **Monitoring kont firmowych** — nie prywatnych

Transparentność — obowiązek art. 50

OBOWIĄZUJE OD 2 SIERPNIA 2026

Jeśli generujesz treści za pomocą AI dla klientów lub odbiorców zewnętrznych, musisz spełnić dwa obowiązki — i ważne jest, żeby wiedzieć, który z nich zaczął obowiązywać kiedy.

Art. 50 ust. 1 — informacja o AI

Obowiązuje od **2 sierpnia 2026**, bez żadnego okresu przejściowego. Musisz informować osoby fizyczne, gdy wchodzi w interakcję z systemem AI — np. chatbot na stronie firmy musi się ujawniać jako bot.

Art. 50 ust. 2 — znakowanie treści

Treści generowane przez AI (deepfake, syntetyczny tekst o sprawach publicznych) muszą być oznaczane. Dla systemów **już działających** przed 2.08.2026 — krótki okres przejściowy do **2 grudnia 2026**.

Warstwa kontraktowa — najczęściej pomijany obowiązek

Nawet jeśli dostawca (OpenAI, Anthropic, Google) formalnie odpowiada za swoje obowiązki GPAL, firma-deployer **musi sama sprawdzić**, co jest w regulaminie, umowie i DPA (Data Processing Agreement).

1

Dane treningowe

Czy dane wpisywane do systemu są używane do trenowania modelu? To pytanie, które musisz zadać przed podpisaniem umowy.

2

Lokalizacja przetwarzania

Gdzie są przetwarzane i przechowywane dane? Czy serwery są w UE czy poza nią?

3

Transfer poza EOG

Czy dane są transferowane poza Europejski Obszar Gospodarczy? Jeśli tak — na jakiej podstawie prawnej?



Dane treningowe — co robią największe platformy?

Stan na maj 2026. Uwaga: liczy się typ konta, nie to czy jest płatne.

Dostawca / Konto	Trenuje model?	Uwagi
OpenAI — API / Team / Enterprise	✗ NIE	Dane nie trafiają do trenowania
OpenAI — Free / Plus / Pro	⚠ MOGĄ	Domyślnie TAK — liczy się "konsument vs. biznes"
Microsoft Azure OpenAI	✗ NIE	DPA zgodny z RODO, hosting w UE
Google Workspace (Gemini) Business/Enterprise	✗ NIE	Dane chronione umową Enterprise
Anthropic Claude — API / for Work / Enterprise	✗ NIE	Bezpieczne dla firm
Anthropic Claude — konta konsumenckie	⚠ TAK (od 28.08.2025)	Domyślnie TAK, do 5 lat, możliwy opt-out

Transfer danych poza EOG — co musisz wiedzieć

Zasadniczy zakaz RODO

Dane osobowe nie mogą być transferowane poza Europejski Obszar Gospodarczy bez odpowiedniej podstawy prawnej — AI Act tego nie zmienia, ale nowe umowy z dostawcami AI muszą ten zakaz uwzględniać.

Jak sprawdzić dostawcę?

Skorzystaj z rejestru Data Privacy Framework: dataprivacyframework.gov/list — certyfikowani dostawcy z USA mają uproszczoną podstawę do transferu danych do Stanów.

Praktyczna wskazówka

Przy podpisywaniu umowy z amerykańskim dostawcą często można wybrać **spółkę europejską** jako stronę kontraktu — np. Microsoft Ireland zamiast Microsoft USA — i uniknąć problemu transferu danych całkowicie.

Kary — trójstopniowy system (art. 99)

AI Act ustawił sufit kar wyżej niż RODO (max 20 mln € / 4% obrotu). Zakres podmiotowy obejmuje cały łańcuch dostaw AI — dostawcę, deployera, importera i dystrybutora.

35M€

lub 7% obrotu

Zakazane systemy AI — manipulacja, social scoring, masowe rozpoznawanie twarzy.
Najwyższy próg.

15M€

lub 3% obrotu

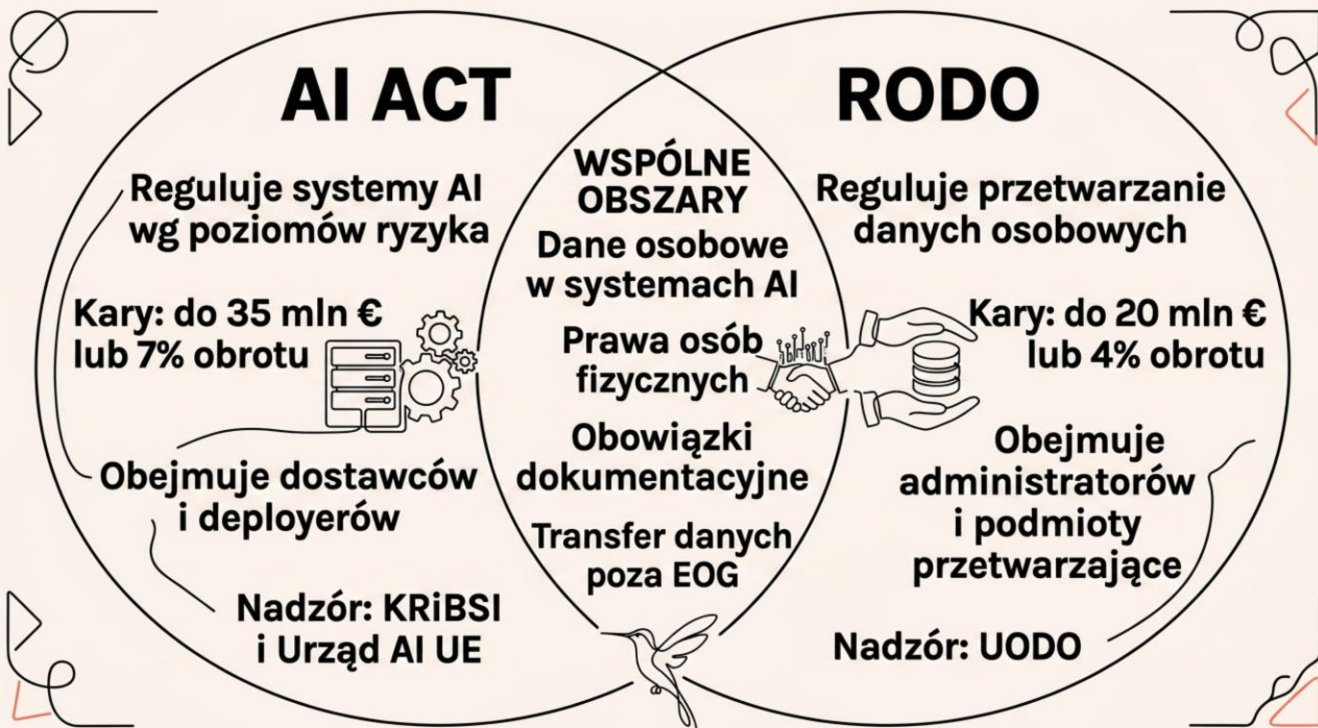
Naruszenia dot. systemów wysokiego ryzyka, GPAI, obowiązku transparentności z art. 50.

7,5M€

lub 1% obrotu

Przekazanie nieprawdziwych lub wprowadzających w błąd informacji organowi nadzorcemu.

AI Act a RODO — jak się uzupełniają



W praktyce firmy muszą spełniać **oba reżimy jednocześnie**. W sprawach AI + dane osobowe właściwy jest nadal **UODO** — nie zastępuje go nowy organ KRiBSI, który nadzoruje wyłącznie przepisy AI Act.

Szybka samoocena — test dla menedżera

Przed wdrożeniem każdego nowego narzędzia AI w firmie zadaj sobie te pytania:

→ Do czego tego używamy?

Czy zastosowanie wchodzi w jeden z obszarów Załącznika III AI Act? (rekrutacja, finanse, edukacja, zdrowie, infrastruktura krytyczna, itp.)

→ Co mówi umowa z dostawcą?

Czy dane trenują model? Gdzie są serwery? Czy mamy DPA? Czy dostawca jest certyfikowany w Data Privacy Framework?

→ Czy spełniamy test trzech warunków?

Wyłącznie wąskie zadanie techniczne + korekta pracy człowieka + brak wpływu na decyzje? Jeśli NIE — jesteśmy deployerem systemu wysokiego ryzyka.

→ Czy pracownicy są przeszkoleni?

Obowiązek AI literacy (art. 4) — czy każda osoba korzystająca z systemu rozumie jak działa i zna jego ograniczenia?

Co zrobić w firmie — plan działania

01

Inwentaryzacja narzędzi AI

Zbierz listę wszystkich narzędzi AI używanych w firmie — oficjalnych i shadow. Bez tej wiedzy nie możesz nic zarządzać.

ćć

Klasyfikacja zastosowań

Dla każdego narzędzia: sprawdź cel zastosowania przez test trzech warunków i Załącznik III. Określ poziom ryzyka.

ćć

Audyt kontraktów z dostawcami

Sprawdź umowy, DPA i regulaminy pod kątem danych treningowych i transferu poza EOG. Renegocjuj jeśli konieczne.

04

Polityka AI i szkolenia

Wprowadź pisemną politykę AI (co wolno, jakich narzędzi używać, jakich danych nigdy nie wklejać) i zorganizuj szkolenia AI literacy.

ćd

Logi i nadzór

Dla systemów wysokiego ryzyka: skonfiguruj automatyczne logowanie, wyznacz osoby nadzorujące, ustal procedurę zgłaszania incydentów.

Podsumowanie — 5 rzeczy do zapamiętania



AI Act już częściowo obowiązuje

Zakazy (art. 5), AI literacy (art. 4) i transparentność (art. 50) są aktywne **już teraz**. Nie czekaj na 2027.



Kontekst, nie model, decyduje

Zwykły ChatGPT może stać się systemem wysokiego ryzyka przez **cel zastosowania** – pytaj "do czego?", nie "co to?"



Test trzech warunków

Szybki sposób na wstępną samoocenę każdego **nowego zastosowania AI** w pracy – 3 pytania, jasna odpowiedź.



Warstwa kontraktowa jest kluczowa

Dane treningowe i transfer poza EOG to kwestie **tak samo ważne** jak sam sposób użycia narzędzia.



Kary wyższe niż w RODO

Do 35 mln € lub 7% obrotu globalnego – warto traktować AI Act poważnie **dziś**, nie czekać na egzekwowanie.

Pytania? Skontaktuj się z działem prawnym lub compliance w swojej firmie – i pamiętaj o obowiązku szkoleń AI literacy dla całego zespołu.